LEXIGRID

Administrator and Deployment Guide

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

LexiGrid 5.54.15 - Native Linux and PostgreSQL 4

1. Prepare the host and database . . . 4
2. Install and migrate . . . 4
3. Create the initial platform administrator . . . 4
4. Activate restricted database access . . . 4
5. Smoke test and configure services . . . 5
6. Complete client acceptance . . . 5

Dedicated PostgreSQL identities . . . 6

Deployment and administration procedures 6

Operating boundary and release evidence . . . 6
Native installation and initial access . . . 6
Native Linux with PostgreSQL commissioning . . . 7
Native lifecycle and process identity . . . 7
Compose deployment . . . 7
Tenant and user administration . . . 8
Maintenance decision and rollback . . . 8
Troubleshooting sequence . . . 8
Qualification checklist . . . 9
Local authenticator policy and optional setup . . . 9
Dedicated PostgreSQL identities . . . 9
Acceptance expiry worker . . . 9

LexiGrid Administrator Guide 10

PostgreSQL restore verification . . . 10
Workflow delivery recovery . . . 10
Required MFA with SAML . . . 10
Active Directory federation . . . 11
Evidence encryption provider validation . . . 11
Governance document extraction . . . 11
User access management . . . 12

LexiGrid - Cross-platform deployment and lifecycle administration 12

Deployment support and qualification . . . 12
Docker on Linux/macOS . . . 12
Docker on Windows (PowerShell) . . . 12

Native Linux/macOS . . . 13
Native Windows (PowerShell) . . . 13
Security and operational prerequisites . . . 13
Troubleshooting . . . 13
Known limitations . . . 14

Active Directory SSO: Entra ID and AD FS **14**

Entra ID using OIDC . . . 14
On-premises AD FS using SAML . . . 15
Enable and verify . . . 15

Upgrade, backup and recovery **16**

Purpose and prerequisites . . . 16
PostgreSQL backup . . . 16
PostgreSQL isolated restore . . . 16
SQLite local recovery . . . 17
Application and key verification . . . 17
Worker restart and duplicate semantics . . . 17
Acceptance record and rollback trigger . . . 17
Dedicated PostgreSQL identities . . . 18

Read-only identity collection for compliance audits **18**

Microsoft Entra ID . . . 18
Active Directory . . . 19
Security and independent approval . . . 20

LexiGrid 5.54.15 - Native Linux and PostgreSQL

Author: Shahryar Jahangir, Aniza Inc.

This distribution initializes an empty database. Keep the original installer and backup for existing deployments. Use this distribution to restore backups created from this schema.

1. Prepare the host and database

Use Linux with Python 3.11+, venv/pip, PostgreSQL 16, PostgreSQL client backup tools, and an approved HTTPS reverse proxy. Install distribution packages for XML security if required by the SAML dependencies. Connected installation uses the pinned requirements.txt; disconnected installations require a separately prepared, target-compatible wheelhouse. Run the application as a dedicated non-root account with a private installation directory. Do not expose PostgreSQL publicly.

Have the DBA create an empty UTF-8 database owned by a dedicated migration account. Initial migrations create the restricted lexigrid_runtime cluster role; the migration account requires role-management privileges and BYPASSRLS for privileged administrative provisioning. Keep those maintenance credentials separate from service credentials. A DBA may instead perform initial setup using a controlled administrative connection. The application must never run as that account. Use private password prompts or approved secret injection; do not put passwords into command history.

2. Install and migrate

Extract the archive, preserve executable permissions and enter LexiGrid. As the dedicated application account, run:

```
./scripts/native/install.sh --database postgres --pg-host 127.0.0.1 --pg-port 5432 --pg-database
client_irm --pg-user lexigrid_owner
```

Replace host, database and owner with the DBA-provisioned values. The installer prompts privately for the database password, installs dependencies into .venv, creates private .env.native keys and upgrades the schema. It does not install PostgreSQL or create the database. Existing .env.native is retained on reinstall. A new PostgreSQL install initially contains the owner connection and must remain offline until step 4.

3. Create the initial platform administrator

Interactive installation offers a named organization and initial platform administrator. Record its generated password privately, change the password in Security and optionally add an authenticator there. If installation was unattended, or no administrator was created, run while the owner connection is still configured:

```
./lexictl admin create-tenant --name "Client organization" --email administrator@example.invalid
--role platform_admin
```

Use the real administrator address. Password entry is private. Do not repeat tenant creation on an existing deployment. Later tenant administrators use the default tenant_admin role. Password recovery and identity binding require an explicit owner maintenance connection through LEXIGRID_ADMIN_DATABASE_URL; they do not overwrite the runtime configuration.

4. Activate restricted database access

Before any application startup, run:

```
.venv/bin/python -m app.provision_runtime --native-config .env.native
```

Enter a separate runtime database password of at least 24 characters. This explicit command configures lexigrid_runtime and replaces only DATABASE_URL in .env.native, retaining all original application keys. The role is cluster-wide: coordinate its credentials if multiple databases share a PostgreSQL cluster. The command refuses already-active runtime

configuration. Keep the owner password in the maintenance secret store, then remove maintenance credential variables from the service environment.

Run read-only readiness diagnostics with the native runtime configuration:

```
.venv/bin/python - <<'PY'
import os
from scripts.native.manager import read_config
os.environ.update(read_config())
from app.diagnostics import main
main()
PY
```

Require ready=true. Diagnostic readiness covers database grants and schema, not external TLS or IdP commissioning.

5. Smoke test and configure services

```
./lexictl start
./lexictl status
curl --fail http://127.0.0.1:8000/health
./lexictl stop
```

Use the example systemd units in scripts/native/systemd. Review the installation path, service account and filesystem permissions before copying them to /etc/systemd/system. Both units load the same private .env.native and must use restricted runtime credentials. The workflow scheduler is a separate service; starting the native API does not start it. Do not run a systemd API and lexictl start concurrently. For systemd deployments use systemctl for lifecycle and inspect the API health endpoint directly.

Terminate TLS at the approved proxy, forwarding to loopback only. Configure an HTTPS hostname, certificates, request size/time limits and log retention for the intended workload. Configure both Microsoft Entra ID OIDC and AD FS SAML if required, using the Active Directory manual. Register exact callback URLs and explicitly bind existing accounts. Enforce MFA at the IdP; qualify recovery before enabling SSO for users.

6. Complete client acceptance

Before serving customer traffic, record results for:

- First sign-in, MFA enrollment, password rotation and revoked old sessions.

- Platform administrator tenant creation and least-privilege tenant user access; a denied foreign-tenant request.

- PDF/DOCX extraction against authorized source text and tables, reviewed draft import, editing and stale-write conflicts.

- SMTP configuration, worker processing, retry visibility and a consented test recipient.

- HTTPS and certificate validation, backups with original keys, isolated restore and expected tenant reads.

- Configured IdP, KMS/Conjur/Vault, audit retention/WORM and SIEM integrations on the actual customer infrastructure.

- Host reboot/service recovery, monitoring, capacity and disaster recovery appropriate to the deployment.

An integration is not accepted solely because settings are present. Windows hosts, external integrations, offline wheel installation and HA/failover require separate target qualification. See docs/MANUAL_INDEX.md for the detailed manuals. No compliance certification is implied.

Dedicated PostgreSQL identities

Database identities must be explicit and separate from an operator's operating-system login. Native installation defaults to `lexigrid_owner` for privileged setup, and the application uses restricted `lexigrid_runtime` credentials after provisioning. A DBA may choose a dedicated maintenance account such as `lexiadmin` using `--pg-user lexiadmin`; create it under the deployment's approved database administration procedure. Migration-created roles use fixed product names, never the current OS username. The installer does not automatically create a personal or privileged account named after the person running it. SQLite uses a database file and has no database login.

For a supplied PostgreSQL URL, put the intended account explicitly before @, for example `postgresql+psycopg://lexigrid_runtime@db.example.invalid/lexigrid` (supply credentials through the approved configuration or secret mechanism). URLs such as `postgresql:///lexigrid` and URLs with `user` / `username` query overrides are rejected before a connection is attempted. Installation, application startup, maintenance, runtime provisioning, diagnostics and the backup script apply the same check. The operating-system username, PGUSER and database-service defaults cannot supply an omitted identity.

Before upgrading an existing PostgreSQL deployment with an implicit username URL, have the DBA supply the approved dedicated account explicitly. Do not rename roles, reset passwords, replace encryption keys or recreate databases simply to satisfy this setting. Existing explicit connections, original credentials and data are retained. Audit records may still identify the actual OS operator separately from the database role.

Deployment and administration procedures

Operating boundary and release evidence

This manual distinguishes application behavior from target-environment qualification. PostgreSQL is the production database; SQLite is for local development/evaluation. Configure and qualify customer Entra/AD FS, KMS and WORM infrastructure separately.

Before each maintenance window, identify the exact installation directory, release VERSION, database type and schema revision, runtime identity, ingress and worker topology. Keep a private change record with expected behavior, rollback conditions and the tested recovery path. Do not collect full environment files in a ticket.

Native installation and initial access

1. Use an isolated target and choose native deployment through install.sh. The installer must not require Docker before native mode is selected.

2. Choose SQLite only for local evaluation, or provision PostgreSQL independently. Native tooling does not install/manage a PostgreSQL server.

3. Keep schema-owner credentials for migration operations and use lexigrid_runtime for the PostgreSQL API. Native startup rejects an owner/superuser connection.

4. Protect .env.native. Existing secrets and database settings must survive reinstall. The installer creates new private configuration at mode 0600 on POSIX.

5. Provision a named tenant and initial administrator through the privileged administrative procedure. Passwords are entered interactively; never use an example password in a real deployment.

6. Start the API, check native status and /health, then open /ui through the approved ingress. The default native binding is loopback.

7. Validate the first sign-in, any mandatory MFA enrollment, tenant identity and one permitted/denied action. Record actual results.

Verification: health belongs to the expected native instance, login uses the expected tenant and the restricted database role is accepted. A healthy unrelated listener is not a successful native startup. A failed child must not leave a misleading active PID marker.

Native Linux with PostgreSQL commissioning

Use the included START_HERE.md for the ordered Linux installation procedure. It covers an independently provisioned PostgreSQL owner database, dependency installation, migrations, initial platform administrator creation, restricted runtime provisioning, TLS and operating-system supervision. Fresh installations make local authenticator enrollment optional (`LEXIGRID_REQUIRE_LOCAL_MFA=0`). Password-only sign-in is available until an authenticator is enabled. Set the local policy to 1 only when the organization requires enrollment. Existing configuration and keys are retained on reinstall.

Before changing the initial DATABASE_URL to runtime credentials, create the platform administrator with `./lexictl admin create-tenant --name "Organization" --email admin@example.invalid --role platform_admin` using the owner connection. Passwords are prompted privately. Then run `.venv/bin/python -m app.provision_runtime --native-config .env.native` and enter a distinct runtime password of at least 24 characters. This explicit operation sets the cluster role password, uses the actual configured database name and replaces only DATABASE_URL in the native file. It refuses an already-active runtime configuration; use your approved role-rotation procedure for existing installations. The lexigrid_runtime role is cluster-wide, so installations sharing a cluster must coordinate its credentials.

For later owner maintenance, inject LEXIGRID_ADMIN_DATABASE_URL into the maintenance process. Do not retain owner credentials in the API or scheduler environment. After first sign-in, use Security to change the bootstrap password; changing a local password revokes existing sessions. SSO passwords are managed by the identity provider.

Native lifecycle and process identity

Use ./start.sh, ./status.sh and ./stop.sh from the verified installation, or the native manager's start/status/stop subcommands. Start accepts an explicit host/port when needed. Preserve the existing binding during a routine restart. Do not widen it to 0.0.0.0 merely to solve a connectivity problem.

The native manager records an instance marker and checks that instance before signaling a process group. An unrelated process on the port must remain running. Stop waits for verified process exit before removing the PID marker. If its grace period expires, it reports failure and retains state; investigate active work before taking an offline snapshot or reusing the port. Never use an arbitrary PID kill as the default troubleshooting step.

Native mode does not install launchd/systemd/Windows services and does not automatically start app.workflow_scheduler. Configure those supervision/scheduling arrangements independently. Avoid starting a second scheduler by accident during recovery.

Compose deployment

1. Review compose.yaml and the approved .env without disclosing credentials. Set the required original mail, MFA, evidence, audit and session keys.

2. Validate rendered configuration locally. Do not paste docker compose config output into tickets because interpolation can expose secrets.

3. Build on a disposable target first. The migration service uses the owner connection; the API/scheduler use restricted runtime credentials.

4. Start services through the release lifecycle scripts. Verify migration completion, PostgreSQL health, API health and scheduler logs separately.

5. Put TLS termination and network restrictions in front of the loopback-bound API. Do not treat container health as TLS/identity qualification.

6. Configure both IdPs explicitly if required. Compose forwards OIDC/SAML/MFA configuration and shares the existing mail configuration key with the scheduler.

7. Verify tenant-scoped reads, a denied foreign-tenant operation, a consented test notification and a recovery check before serving customer traffic.

Complete commissioning on the intended deployment. Production reverse proxy, certificates, policy, external integrations, resource limits and failover remain deployment-specific.

Tenant and user administration

Platform administrators can create a named tenant and its initial tenant administrator atomically. Tenant administrators create/view users in their authenticated tenant; a contact label is not a user role. Login tenant names are discoverable before authentication and do not imply access.

Use Administration to manage supported tenant/user operations. Check the recorded actor and tenant in the audit trail after a change. Use Change access to deactivate/reactivate tenant users or change their permitted role. Access changes revoke prior sessions, require the current security revision and are audited. Self-changes and platform-administrator changes are blocked in this UI; privileged identity binding and password recovery use owner administration. Test lower-role denial through the API, not only hidden buttons.

Maintenance decision and rollback

Stop workers when a schema/data change requires a quiet queue; allow accepted sends to finish and account for at-least-once delivery if a process is interrupted. Back up the database consistently, retain original keys separately and restore into an isolated target before changing installed data. Use the recovery manual for revision support and grants.

Before activating updated code, check migration head and cold-start the same code against the restored/upgraded copy. After maintenance, verify current revision, original row counts/fingerprints, health, tenant reads and the actual affected UI flow. Refresh the browser; source on disk does not prove a long-running process has loaded it.

Rollback must preserve the last consistent data state and compatible application code. Do not run an unsupported downgrade to remove audit protections or delivery history. Keep the verified recovery image and investigate the specific failure.

Troubleshooting sequence

- API not healthy: confirm the intended process/port, private native log, configuration validation and schema compatibility. Do not print secrets or SQL parameter dumps.

- Authentication fails: confirm tenant and active account, federation binding, expiry/state correlation and asserted MFA policy. Do not weaken MFA to clear an unexplained error.

- Imports are inaccurate: identify format/type, source location, warnings and hash; use a representative authorized source locally. Never bulk-delete existing records as a parser repair.

- Mail is queued: inspect worker activation, due/backoff state, lease and SMTP configuration. Browser SMTP edits do not start a stopped worker.

- Evidence fails: distinguish provider access 503 from integrity 409; retain original keys and ciphertext.

- Restore fails: leave traffic away from the target, validate archive revision/checksum/grants and use the protected recovery copy. Never delete the database to force a green install.

Qualification checklist

Customer IdP round trips/MFA, external Conjur/Vault rotation/recovery, independent Object Lock retention, SIEM/TLS, Windows native, disconnected artifact installation and HA/failover must be qualified on authorized target infrastructure. Measured performance/accessibility and a deployment-specific access review remain separate acceptance work. No compliance certification or enterprise parity is implied by local tests.

Local authenticator policy and optional setup

Set LEXIGRID_REQUIRE_LOCAL_MFA=0 to allow password sign-in before enrollment; set it to 1 to require local enrollment. Without this variable, the legacy LEXIGRID_REQUIRE_MFA value is used for local accounts. LEXIGRID_REQUIRE_MFA continues to enforce configured OIDC/SAML MFA policy independently. Optional enrollment does not disable a factor that has already been enabled.

Users may open Security > Add authenticator later, scan the locally generated QR code, and enter the app's current six digits. Reopening pending setup retains its key. Successful confirmation issues a new session and revokes older sessions, avoiding an immediate attempt to reuse the consumed code. Cancel setup discards only pending enrollment. Keep original encryption keys and phone/server clocks synchronized.

Dedicated PostgreSQL identities

Database identities must be explicit and separate from an operator's operating-system login. Native installation defaults to `lexigrid_owner` for privileged setup, and the application uses restricted `lexigrid_runtime` credentials after provisioning. A DBA may choose a dedicated maintenance account such as `lexiadmin` using `--pg-user lexiadmin`; create it under the deployment's approved database administration procedure. Migration-created roles use fixed product names, never the current OS username. The installer does not automatically create a personal or privileged account named after the person running it. SQLite uses a database file and has no database login.

For a supplied PostgreSQL URL, put the intended account explicitly before `@`, for example `postgresql+psycopg://lexigrid_runtime@db.example.invalid/lexigrid` (supply credentials through the approved configuration or secret mechanism). URLs such as `postgresql:///lexigrid` and URLs with `user` / `username` query overrides are rejected before a connection is attempted. Installation, application startup, maintenance, runtime provisioning, diagnostics and the backup script apply the same check. The operating-system username, PGUSER and database-service defaults cannot supply an omitted identity.

Before upgrading an existing PostgreSQL deployment with an implicit username URL, have the DBA supply the approved dedicated account explicitly. Do not rename roles, reset passwords, replace encryption keys or recreate databases simply to satisfy this setting. Existing explicit connections, original credentials and data are retained. Audit records may still identify the actual OS operator separately from the database role.

Acceptance expiry worker

LexiGrid starts a dedicated risk-acceptance scan once per minute in the API process, independently of SMTP. The default is LEXIGRID_ACCEPTANCE_WORKER=1. Disabling it requires an independently managed scanner; acceptance views still evaluate expiry, but persisted risk status and review events depend on scanning. Inspect structured risk.acceptance expiry and tenant_scan.failed events. A damaged tenant's provenance blocks that tenant's transaction and requires investigation; other tenants continue. Keep the original audit signing key and runtime credentials. No existing accepted risk is reclassified unless it has a new bound acceptance whose expiry is due.

LexiGrid Administrator Guide

See `docs/distribution/LexiGrid_Administrator_Guide.pdf` for detailed deployment, tenant, AI, logging, upgrade, backup, uninstall, and acceptance procedures. Also see CLI and Security Operations PDFs.

PostgreSQL restore verification

Restore to an isolated recovery database first. Use a libpq connection URL for the target schema owner and provision the restricted `lexigrid_runtime` login in the target PostgreSQL cluster. Supply the archive and its adjacent `.sha256` manifest to `scripts/restore_postgres.sh` with `RESTORE_CONFIRM=RESTORE_LEXIGRID`.

Use a backup compatible with the installed database schema. The restore applies runtime grants and validates forced tenant row-level security in the archive transaction. Retain the original encryption keys. Verify API health, a scoped tenant read, and application data before routing traffic to the recovery database.

When running audit checkpoints with the restricted PostgreSQL role, use `python -m app.audit_anchor create --tenant-id TENANT_UUID --output CHECKPOINT_PATH`. The WORM publisher reads the same scope from `LEXIGRID_AUDIT_TENANT_ID`. A whole-database checkpoint requires an independently controlled database role that can read every tenant. Runtime roles cannot update or delete existing audit or workflow decision records.

Native PostgreSQL startup enforces database security checks. Keep the schema-owner connection for migration commands and configure `DATABASE_URL` in `.env.native` with the restricted `lexigrid_runtime` connection before starting the API. The native process refuses an owner or superuser connection even if an older configuration disables the check. SQLite native mode is intended for development and evaluation.

Workflow delivery recovery

The workflow delivery ledger records per-channel state and enforces tenant-scoped access. Before maintenance, stop the scheduler, verify a protected backup, and validate the restored copy and runtime grants before restarting the API and scheduler.

Enabled workflow channels make at most five automatic attempts. Failures back off for 2, 4, 8 and 16 minutes; scheduler polling may delay execution. Workers hold a ten-minute lease. An expired lease can be reclaimed, and its old token cannot complete the newer attempt. The inbox shows channel status. Tenant administrators and risk managers may use the Workflows recovery card to request one additional attempt for a failed channel, recording a reason and the current attempt count. Platform administrators have the same controls within their selected tenant. Duplicate or stale requests return a conflict and require refresh. Attempts remain cumulative, and a successful channel is not resent when another channel fails.

Delivery is at least once: a process failure after remote acceptance but before the database commit may cause a duplicate. Webhooks carry a stable notification `Idempotency-Key`; workflow emails carry a stable `Message-ID`. Receivers should deduplicate using those values. An email delivery timestamp records SMTP acceptance, not proof of final recipient delivery or reading. Disabled channels retain their state until re-enabled. Last-error fields store the exception class without transport credentials or message contents.

Required MFA with SAML

With `LEXIGRID_REQUIRE_MFA=1`, SAML assertions must contain an approved authentication context after the toolkit validates both signatures, issuer, audience, validity times and request correlation. Password-only assertions are rejected before issuing an application token. SAML authentication requests advertise the approved contexts using exact comparison. The defaults are `https://refeds.org/profile/mfa` and `https://refeds.org/profile/mfa/phr`, which identify general and phishing-resistant MFA in the REFEDS MFA profile (https://refeds.org/profile/mfa). This context check trusts the configured IdP's assertion; it does not itself perform the factors or certify IdP conformance.

For an IdP with a different MFA signal, the operator may set `LEXIGRID_SAML_MFA_CONTEXTS` to a comma-separated list of authentication-context URIs. The operator must verify that the IdP uses each configured URI only when MFA actually occurred. A generic password context must not be placed on this list. Empty or malformed configuration is rejected. For native deployment, configure the existing environment file; for Compose, pass these variables explicitly in the API service environment, alongside the other SAML settings. Restart the API after configuration changes and verify a signed MFA login plus rejection of a signed password-only login using a pre-provisioned test account.

When MFA is not required, existing signed SAML login behavior is retained. Tenant binding, explicit user provisioning and replay rejection still apply. Malformed base64 or XML returns a generic authentication error without exposing parser details to the client. The remediation does not alter user records, keys or schema. Customer IdP configuration and interoperability still require qualification in the target environment.

Active Directory federation

See Active Directory SSO setup for simultaneous Microsoft Entra ID (OIDC) and AD FS (SAML) configuration, MFA assertion requirements, explicit account binding, native certificate formatting and browser activation checks. The login screen discovers configured providers and uses the selected tenant for each sign-in. Installed directory configuration must be supplied and qualified before production activation.

Evidence encryption provider validation

`LEXIGRID_KMS_PROVIDER` must be exactly `local`, `vault` or `conjur`. If the variable is absent, legacy local mode remains the default. An explicitly empty, misspelled or differently capitalized value is rejected at startup before development bootstrap or database operations. Correct the setting using the existing configuration and restart; do not regenerate keys to address a provider-selection error.

Evidence uploads return HTTP 503 if the selected provider cannot encrypt the file. Failed encryption does not create an evidence record or a successful upload audit event, and the API response does not expose provider credentials or error payloads. There is no automatic fallback from a remote provider to local encryption. After restoring provider availability, the user may submit the upload again.

Existing evidence is decrypted according to its stored envelope, using its original provider/key material rather than the current provider for new writes. Retain the original local key and access to historical Conjur/Vault keys when changing the new-upload provider. This remediation does not rotate keys, re-encrypt existing records or change database schema. Live external KMS connectivity and rotation/recovery still require deployment-specific qualification.

Evidence downloads distinguish provider access failures from integrity failures. Vault request failures and Conjur access/configuration failures return HTTP 503 without changing the stored record. Investigate service reachability, credentials, custom CA files, policy and access to historical keys; retry after restoring provider access. An unavailable provider or missing historical key does not by itself establish ciphertext corruption. Do not regenerate keys or replace the stored evidence as an outage workaround.

Malformed envelopes, failed local/Conjur AES-GCM authentication and a decrypted-content hash mismatch continue to return HTTP 409. Remote providers may reject a decrypt request for several reasons; their generic request failures return 503 rather than claiming proven corruption. Provider error bodies, credentials and evidence contents are not included in the API error response. Tenant authorization runs before provider access.

Governance document extraction

See Reviewed document import for PDF/DOCX/TXT controls, frameworks, policies and requirements, supported source structures, source-location review, default ownership, atomic conflict handling and extraction limits. Choose the record type in Document Extraction before uploading. Existing records are preserved; new controls remain planned and policies remain draft.

The supplied ISO/IEC 27001:2022 PDF now uses a dedicated profile separating framework metadata, management clauses and Annex A controls while excluding front matter. See Reviewed document import. Validate extraction against your authorized source before importing reviewed records.

User access management

In Administration, select Change access beside a tenant user to change role or active state. Access changes revoke sessions and record an audit event. Self-changes, platform-administrator changes and stale security revisions are rejected. Deactivation preserves records and authorship; reactivation does not revive earlier tokens. Federated identity binding and owner recovery remain privileged operations.

LexiGrid - Cross-platform deployment and lifecycle administration

Author: Shahryar Jahangir, Aniza Inc. **Release:** 5.54.15

Deployment support and qualification

Host	Docker Compose deployment	Native Python application
Linux (x86-64)	Compose CLI + Docker Engine	Python 3.11+, PostgreSQL recommended
macOS (Intel/Apple Silicon)	Docker Desktop + Compose v2	Python 3.11+, PostgreSQL recommended
Windows 10/11/Server	Docker Desktop/compatible Docker engine with Linux containers	Python 3.11+, PowerShell, PostgreSQL recommended

These are supported *installation paths in source code*, not certified operating-system builds. Native installation and third-party wheel compatibility must be exercised on each target OS. For production use PostgreSQL, enterprise TLS termination, an identity provider, secrets manager and centralized monitoring.

Docker on Linux/macOS

```
./scripts/install.sh
./scripts/status.sh
./scripts/stop.sh
./scripts/start.sh
./scripts/uninstall.sh
```

Uninstall keeps the database unless explicitly confirmed. Installer keeps existing `.env` secrets and database volume. Review `compose.yaml` and configure an approved HTTPS reverse proxy; the API listens on loopback port 8000 by default.

Docker on Windows (PowerShell)

```
powershell -ExecutionPolicy Bypass -File .\scripts\lexigrid.ps1 install
.\scripts\lexigrid.ps1 status
.\scripts\lexigrid.ps1 stop
.\scripts\lexigrid.ps1 start
.\scripts\lexigrid.ps1 uninstall
```

The PowerShell uninstall command always preserves database volumes and configuration. To delete database volumes, use a separately authorized database-retention procedure and take a verified backup first.

Native Linux/macOS

```
./scripts/native/install.sh --database postgres --pg-host DBHOST --pg-database lexigrid --pg-user
lexigrid_owner
./scripts/native/start.sh
./scripts/native/status.sh
./scripts/native/stop.sh
./scripts/native/uninstall.sh
```

Use a restricted runtime database role for the application. The initial migration requires a separate database schema-owner connection; do not reuse a privileged schema owner for ongoing application runtime. Native installation reads `.env.native` and creates `.venv`. The `install` command invokes Alembic migrations using the provided connection. To install dependencies without migrating, use `--skip-migrations`, run the migration separately with a schema-owner connection, then replace DATABASE_URL with a runtime-role connection before starting.

The native launcher runs the **API process only**. To enable overdue-workflow checks, configure an operating-system-managed service that executes `python -m app.workflow_scheduler` in the virtual environment with the same runtime environment. Do not run multiple independent schedulers without coordination.

Native Windows (PowerShell)

```
.\scripts\lexigrid.ps1 install -Mode native -DatabaseUrl
'postgresql+psycopg://USER:PASS@DBHOST:5432/lexigrid'
.\scripts\lexigrid.ps1 start -Mode native
.\scripts\lexigrid.ps1 status -Mode native
.\scripts\lexigrid.ps1 stop -Mode native
.\scripts\lexigrid.ps1 uninstall -Mode native
```

Install Python 3.11+ and ensure `py -3` or `python` resolves. Use Windows ACLs to restrict `.env.native`; on Unix it is created with permissions 0600. Do not store production credentials in source control. Python dependencies, including SAML XML-security dependencies, may require additional platform packages and must be validated on the actual host.

Security and operational prerequisites

1. Use PostgreSQL with row-level security, restricted runtime credentials and migrations run by a separate schema owner.

2. Use TLS 1.2+ (prefer 1.3) at an approved ingress/reverse proxy. Native API defaults to `127.0.0.1:8000`; do not expose it directly on the internet.

3. Store credentials in an approved secret manager; local env files are an installation convenience, not a full production secrets architecture.

4. Configure and validate SSO, MFA, Vault Transit, immutable audit storage and monitoring before handling regulated data.

5. Verify a full database restore and all database schema migrations against a representative staging database.

6. Perform target-host installation, stop/start, rollback, disaster recovery, SSO and multi-tenant isolation tests before production signoff.

Troubleshooting

- Native logs: `run/native.log`.

- Docker logs: `docker compose --env-file .env -f compose.yaml logs --tail=200 api workflow-scheduler`.

- Native status probes `http://127.0.0.1:8000/health` (or configured port).

- If migration fails, **do not** delete the database. Inspect the error, restore from verified backup if required, and correct the schema-owner connection.

Known limitations

The native lifecycle manager does not install a systemd/launchd/Windows service, does not start the workflow scheduler, and does not provision PostgreSQL. The Windows PowerShell Docker deployment has not been executed on a Windows host in this environment. The Docker deployment and real production integrations require separate validation. These limitations are release gates, not hidden assumptions.

Active Directory SSO: Entra ID and AD FS

LexiGrid can expose Microsoft Entra ID (OIDC) and on-premises AD FS (SAML) sign-in together. Each deployment has one configured OIDC issuer and one configured SAML IdP. Users select their LexiGrid organization before choosing a provider. Only pre-provisioned, active accounts explicitly bound to the provider identity can authenticate. Directory groups and token roles do not assign LexiGrid permissions automatically.

Qualify sign-in, sign-out, asserted MFA, denied identities and recovery against your configured directory before enabling customer traffic. Preserve existing encryption keys and administrative recovery credentials.

Entra ID using OIDC

Register a Web application with an exact HTTPS redirect URI:

```
https://YOUR_LEXIGRID_HOST/api/auth/oidc/callback
```

Configure these variables in the existing native environment file or Compose environment, using your approved secret storage for the client secret:

```
LEXIGRID_OIDC_ISSUER=https://login.microsoftonline.com/YOUR_DIRECTORY_TENANT_ID/v2.0
LEXIGRID_OIDC_CLIENT_ID=YOUR_APPLICATION_CLIENT_ID
LEXIGRID_OIDC_CLIENT_SECRET=YOUR_CLIENT_SECRET
LEXIGRID_OIDC_REDIRECT_URI=https://YOUR_LEXIGRID_HOST/api/auth/oidc/callback
LEXIGRID_OIDC_LABEL=Microsoft Entra ID
LEXIGRID_REQUIRE_MFA=1
```

The issuer must be the exact issuer returned by tenant-specific discovery. Generic `common` or `organizations` discovery is not supported by the exact-issuer check. The application uses authorization code flow with PKCE. The application requests `openid email profile`; no Microsoft Graph access is required for this flow.

Bind the user's verified issuer and application-specific `sub` from an independently validated ID token to an existing LexiGrid user. Use the schema-owner connection for this audited administrative command:

```
LEXIGRID_ADMIN_CONFIRM=YES python -m app.admin_cli bind-oidc \
  --tenant-id LEXIGRID_TENANT_UUID --email USER_LOCAL_EMAIL \
  --issuer https://login.microsoftonline.com/YOUR_DIRECTORY_TENANT_ID/v2.0 \
  --subject VERIFIED_APPLICATION_SPECIFIC_SUBJECT
```

Do not substitute an email, UPN or Entra object ID for `sub`. The binding command revokes prior application sessions. Authentication selects the local account by LexiGrid tenant plus issuer and subject, without requiring a matching email claim. Microsoft documents email and preferred username as mutable and unsuitable for authorization in its ID token claims reference (https://learn.microsoft.com/en-us/entra/identity-platform/id-token-claims-reference).

When MFA is required, LexiGrid accepts an explicit signed `amr` MFA assertion, a password plus supported second-factor method, or an explicitly configured MFA authentication context. A lone `otp`/hardware method does not satisfy the check. For Entra tokens without a suitable `amr`, configure a Conditional Access authentication context whose policy requires MFA, then set its exact identifier:

```
LEXIGRID_OIDC_MFA_ACRS=c1
```

`c1` is only an example, not a built-in MFA guarantee. The operator must confirm that the configured context policy requires MFA for every permitted user. LexiGrid requests that context in the ID token and verifies the signed `acrs` value; unknown or absent contexts are rejected unless the signed `amr` separately proves MFA. Context configuration is described in Microsoft's Conditional Access authentication context guide (https://learn.microsoft.com/en-us/entra/identity-platform/developer-guide-conditional-access-authentication-context).

On-premises AD FS using SAML

Configure an AD FS relying-party trust with the LexiGrid SP entity ID and HTTPS ACS callback. AD FS must sign both the response and assertion. Supply the IdP signing certificate and an appropriate stable NameID claim. Configure:

```
LEXIGRID_SAML_SP_ENTITY_ID=https://YOUR_LEXIGRID_HOST
LEXIGRID_SAML_ACS_URL=https://YOUR_LEXIGRID_HOST/api/auth/saml/acs
LEXIGRID_SAML_IDP_ENTITY_ID=YOUR_ADFS_ENTITY_ID
LEXIGRID_SAML_IDP_SSO_URL=https://YOUR_ADFS_HOST/adfs/ls/
LEXIGRID_SAML_IDP_CERT=YOUR_IDP_SIGNING_CERTIFICATE_PEM
LEXIGRID_PUBLIC_HOST=YOUR_LEXIGRID_HOST
LEXIGRID_SAML_LABEL=Active Directory Federation Services
LEXIGRID_REQUIRE_MFA=1
LEXIGRID_SAML_MFA_CONTEXTS=http://schemas.microsoft.com/claims/multipleauthn
```

For the single-line native environment format, enter the PEM value without enclosing quotes and replace each certificate newline with literal `\n`. Both actual PEM newlines and escaped newlines are accepted. Do not paste a multiline certificate as several native configuration lines.

The `http://schemas.microsoft.com/claims/multipleauthn` value is an authentication-context identifier; LexiGrid does not fetch it over HTTP. The actual ACS/SSO transport must use HTTPS. Microsoft discusses this MFA context in its AD FS SSO troubleshooting guidance (https://learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/troubleshoot-ad-fs-sso-issue). Configure and verify that AD FS returns the approved value as the signed assertion's AuthnContextClassRef after MFA. An authentication-method attribute alone is not accepted by this adapter's context check. Missing context support must not be worked around by allowing a password-only context or disabling MFA.

Bind the independently verified stable NameID to an existing account:

```
LEXIGRID_ADMIN_CONFIRM=YES python -m app.admin_cli bind-saml \
  --tenant-id LEXIGRID_TENANT_UUID --email USER_LOCAL_EMAIL \
  --subject VERIFIED_STABLE_NAMEID
```

Both identity bindings can belong to the same local account. Roles, tenant membership and account activation remain managed in LexiGrid. Subject changes and certificate rollover require controlled administrative updates and interoperability verification.

Enable and verify

After configuring the providers, restart the API using the existing deployment procedure. Compose now forwards both providers' variables and the MFA policy. The login page shows each provider only when its required configuration is present; incomplete configuration does not produce an active sign-in button. Configuration presence does not prove IdP connectivity or policy correctness.

Use a nonproduction, provisioned account to verify both providers independently: successful MFA login reaches the workspace, password-only login is rejected when MFA is required, the wrong organization is denied, disabled/unbound users are denied, and the audit trail contains one event for each successful sign-in. Browser callbacks use signed state and scoped secure cookies, return a nonce-protected HTML handoff, store the token in same-origin session storage, and

navigate to `/ui`. Tokens are not placed in URL queries or fragments. Direct API starts without `ui=true` retain JSON callback responses.

No installed environment, production IdP or customer database is modified by adding this configuration support. A deployment-specific restore path and access checks remain prerequisites for production activation.

Upgrade, backup and recovery

Purpose and prerequisites

This distribution initializes an empty database. Keep the original installer and backup for existing deployments. Use this distribution to restore backups created from this schema.

Restore data, tenant boundaries and runtime permissions together. A database dump alone is not a complete recoverable deployment. Retain the compatible code release, VERSION, schema revision, original evidence/MFA/mail/audit/anchor keys, identity trust configuration, logging configuration and required external-provider access. Store secrets separately under controlled recovery access.

Verify the restored schema against the application before starting the service. Investigate duplicate reminder schedules without deleting records automatically.

PostgreSQL backup

1. Use the approved database backup role/owner connection and a private backup directory. The script expects a libpq PostgreSQL URL, not the SQLAlchemy +psycopg driver suffix.

2. Run scripts/backup_postgres.sh using approved secret injection. Avoid command-line password literals and shell history containing credentials.

3. Keep the generated .dump and adjacent .sha256 manifest together. The backup contains sensitive tenant data; protect/encrypt it before transfer to independent storage.

4. Verify protected file permissions and the manifest. A checksum is integrity evidence, not encryption or proof that a restore works.

5. Restore a copy into an isolated database and verify application access before calling the backup recoverable.

The backup script uses unique staged names to avoid same-second collisions. It must not overwrite an earlier archive as a routine way to make a backup succeed.

PostgreSQL isolated restore

1. Provision an isolated target schema owner and restricted lexigrid_runtime login. Prevent customer traffic and workers from reaching it.

2. Retain the supplied archive and checksum sidecar. Set RESTORE_CONFIRM=RESTORE_LEXIGRID only for the intended recovery target.

3. Set DATABASE_URL to the target owner's libpq URL and invoke scripts/restore_postgres.sh ARCHIVE_PATH. This is a data-replacing operation; do not target the active database casually.

4. The script hashes the supplied archive even if a legacy manifest refers to an old absolute path. Tampering must be rejected before restore.

5. Archive restoration, runtime grants, forced-RLS and history privilege checks execute in one transaction. SQL failure rolls back the restore.

6. Restore an archive with the schema for this distribution. Keep a copy of the compatible installer with each protected backup.

7. Verify the restored schema with deployment diagnostics. Configure the API with runtime credentials and original keys.

Expected result: preserved counts and selected content fingerprints, no foreign-tenant visibility, denied runtime history mutation, denied protected outbox/delivery deletion and a healthy compatible API. A restore returning success is not the final traffic-switch approval.

SQLite local recovery

SQLite is development/evaluation mode. Use SQLite's online backup API for a consistent copy; copying an active database file alone can miss WAL state. Create the destination privately before writing, run PRAGMA integrity_check and foreign_key_check, and retain an unchanged original snapshot.

Restore to a separate path. Run Alembic against that copy, compare all original table counts/content fingerprints and cold-start updated code with outbound workers disabled. A verified copy is the precondition for an approved installed upgrade, not permission to experiment on the only original database.

For a quiet installed upgrade, stop/verify the native instance, finish outstanding work, take a final snapshot, validate the final restored copy, migrate the intended database and check all original records before restart. Preserve the bind address and environment keys. If validation fails, keep traffic stopped and use the verified compatible recovery path.

Application and key verification

Authenticate a designated test account in the intended tenant and verify one existing record, an evidence download, configuration decryption, an audit read and a foreign-tenant denial. Test each required IdP and MFA policy independently. Original local evidence may require the legacy evidence key even after new writes select Vault or Conjur. A restored mail configuration needs the original shared LEXIGRID_MAIL_CONFIG_KEY.

Do not generate replacement keys to solve a read error. Provider 503 may mean lost access, credentials, CA trust or missing historical key availability; investigate before declaring corruption. Failed authentication/hash checks remain integrity errors. Key recovery/rotation must be exercised with the actual provider.

Worker restart and duplicate semantics

Re-enable only the designated workers/scheduler after the restored database is verified. Inspect queued/failed/sending/retry states and leases before manual recovery. A process may have sent a message before recording success. Keep stable notification IDs and gateway deduplication; do not reset attempt counters to suppress evidence of retries.

Acceptance record and rollback trigger

Record release/schema, backup manifest identity, protected recovery location, counts/fingerprints, runtime role, tenant-negative tests, key/evidence reads, worker decisions and traffic-switch result. Keep credentials out of that record. Missing records, changed existing fingerprints, a privileged API role, broken RLS, unavailable original keys or an unhealthy cold start are rollback/hold conditions.

Complete a recovery exercise against an isolated target. Verify archive checksums, expected row counts, restricted runtime grants, tenant reads and original key recovery before approving production recovery. Test HA and failover separately against the intended infrastructure.

Dedicated PostgreSQL identities

Database identities must be explicit and separate from an operator's operating-system login. Native installation defaults to `lexigrid_owner` for privileged setup, and the application uses restricted `lexigrid_runtime` credentials after provisioning. A DBA may choose a dedicated maintenance account such as `lexiadmin` using `--pg-user lexiadmin`; create it under the deployment's approved database administration procedure. Migration-created roles use fixed product names, never the current OS username. The installer does not automatically create a personal or privileged account named after the person running it. SQLite uses a database file and has no database login.

For a supplied PostgreSQL URL, put the intended account explicitly before `@`, for example `postgresql+psycopg://lexigrid_runtime@db.example.invalid/lexigrid` (supply credentials through the approved configuration or secret mechanism). URLs such as `postgresql:///lexigrid` and URLs with `user` / `username` query overrides are rejected before a connection is attempted. Installation, application startup, maintenance, runtime provisioning, diagnostics and the backup script apply the same check. The operating-system username, PGUSER and database-service defaults cannot supply an omitted identity.

Before upgrading an existing PostgreSQL deployment with an implicit username URL, have the DBA supply the approved dedicated account explicitly. Do not rename roles, reset passwords, replace encryption keys or recreate databases simply to satisfy this setting. Existing explicit connections, original credentials and data are retained. Audit records may still identify the actual OS operator separately from the database role.

Read-only identity collection for compliance audits

Author: Shahryar Jahangir, Aniza Inc.

Microsoft Entra ID

Create a dedicated app registration in the directory to be audited. Assign the Microsoft Graph **application** permissions **Policy.Read.All** and **AuditLog.Read.All**, and have the authorized directory administrator grant consent. LexiGrid does not create the registration, grant consent or expand directory permissions itself. Keep SSO and audit-collection registrations separate. Follow your organization's credential-management procedures.

In **Compliance Audits -> Configure read-only Microsoft Entra connector**, enter a recognizable name, the directory tenant ID, application client ID, client secret and a sign-in lookback of 1-30 days. A tenant or platform administrator saves this configuration. The credential is encrypted with the existing local, Vault or Conjur evidence-encryption provider and is never returned by the connector API. To rotate, configure the replacement connector, verify authorized reads and disable the old connector. Disabling collection preserves historical evidence.

This version supports commercial Microsoft endpoints only. The token request uses the selected directory at login.microsoftonline.com; Graph reads use graph.microsoft.com. Government and China cloud endpoints are not configured by this connector. Disconnected installations can use reviewed offline evidence and AD snapshots; Entra collection requires approved outbound HTTPS connectivity. No collection runs on startup or merely when a risk is opened.

On a scoped audit, choose the connector and select **Collect read-only Entra observations**. The collector obtains a client-credentials token and issues GET requests for:

- `/v1.0/policies/identitySecurityDefaultsEnforcementPolicy`
- `/v1.0/identity/conditionalAccess/policies`
- `/v1.0/auditLogs/signIns`, restricted to the selected observation period and required fields.

The collector follows all returned pages for an approved resource. It refuses redirects, foreign pagination hosts, changed resource paths and repeated page links. It uses a 20 MiB collection byte budget; exceeding it produces an incomplete-collection gap, not a partial passing sample. A shorter observation period may be required. Credentials are sent

only to Microsoft's fixed token endpoint and bearer tokens only to approved Graph resources. HTTP failures are reported without raw credential-bearing provider responses.

The four initial checks are:

Check	Dimension	Precisely what is tested
Security defaults configuration	Implementation	The retrieved isEnabled flag is true.
Enabled MFA / authentication-strength policy	Implementation	At least one enabled policy includes the specified grant; scope and exclusions still need review.
Legacy-client blocking policy	Implementation	An enabled policy blocks exchangeActiveSync and other legacy clients; actual coverage is not inferred.
MFA reported on successful interactive sign-ins	Effectiveness observation	All successful interactive events in the retrieved period report multiFactorAuthentication; missing observations are insufficient evidence.

Sign-in licensing, permissions, retention and service availability determine which observations can be retrieved. A configuration check passing is not an entire-control compliance pass. Event results are bounded historical observations reported by Entra, not independent credential challenges. Review policy conditions, exceptions, authentication-strength definitions, unobserved accounts/applications and actual scope before drawing a control conclusion.

Microsoft references: security defaults API (https://learn.microsoft.com/en-us/graph/api/identitysecuritydefaultsenforcementpolicy-get?view=graph-rest-1.0), Conditional Access policies API (https://learn.microsoft.com/en-us/graph/api/conditionalaccessroot-list-policies?view=graph-rest-1.0), sign-in API and permissions (https://learn.microsoft.com/en-us/graph/api/signin-list?view=graph-rest-1.0).

Active Directory

Download **Collect-LexiGridAD.ps1** from Compliance Audits. Run it on an authorized Windows host with the RSAT ActiveDirectory PowerShell module and read access to the specified domain. Optional Security event retrieval also needs appropriate read access to the chosen server's Security log. Do not grant directory-write privileges for this collector or bypass your organization's script-signing/execution policy.

Example using fictional hostnames; use a new output filename:

```
.\Collect-LexiGridAD.ps1 -Server dc01.example.invalid -OutputPath .\LexiGrid_AD_Snapshot.json
-IncludeSecurityEvents
```

The script uses Get-ADDomain, Get-ADDefaultDomainPasswordPolicy, Get-ADUser and Get-ADUserResultantPasswordPolicy. It inventories enabled accounts and their effective policies, including fine-grained policies rather than assuming the domain default applies to everyone. Selected account flags are collected; account identities are hashed, credentials and security-event message bodies are not exported. Missing attributes remain unknown. Optional Get-WinEvent reads are limited to the explicitly selected server and stated observation period. AD settings are not modified. The script refuses to overwrite an existing evidence file.

Upload the generated JSON using **Evaluate read-only AD snapshot**. Set the password-length and lockout thresholds to the organization's documented criteria. These defaults are not universal NIST, ISO or CJIS requirements. The collector checks:

- effective minimum password lengths;

- reversible-encryption settings;

- effective account-lockout thresholds;

- password-required flags for enabled accounts;

- Kerberos preauthentication flags;

- unconstrained-delegation flags requiring review;

- optional sampled successful-logon event observations.

An incomplete collection or missing/wrongly typed attribute cannot become a pass. Snapshots older than 30 days remain insufficient evidence. A local hash proves content identity only: an uploaded snapshot is operator-submitted, not independently authenticated by LexiGrid. Independently verify the collector, source-system identity, observation period and relevant access before recording a tested conclusion. Sampled logon events establish only the presence of those observations, not complete audit retention, alerting, MFA or every domain controller's protection.

The collector's syntax and runtime were verified in Microsoft PowerShell with isolated mock directory commands. A real Windows RSAT/AD connection must be validated in the client environment; no real client AD domain was accessed during release testing.

Microsoft references: Get-ADDefaultDomainPasswordPolicy (https://learn.microsoft.com/en-us/powershell/module/activedirectory/get-addefaultdomainpasswordpolicy?view=windowsserver2025-ps), Get-ADUserResultantPasswordPolicy (https://learn.microsoft.com/en-us/powershell/module/activedirectory/get-aduserresultantpasswordpolicy?view=windowsserver2025-ps).

Security and independent approval

Only existing tenant/platform administrators configure or disable Entra credentials. Tenant/platform administrators, risk managers and auditors create scopes, collect evidence and record reviews. Ordinary viewers can read audit results in their own workspace but cannot run collection or alter conclusions. Finalization requires an authorized administrator or auditor different from the audit creator, the existing audit-signing configuration, catalogue-completeness evidence and no unresolved applicable safeguards.

Evidence/configuration uses the existing encryption provider with tenant- and record-bound context. No secret-key rotation, authentication policy change, schema migration or SSO reconfiguration is required by this feature. Operation logs retain IDs, hashes, states and safe collection failures; they do not copy secrets, raw evidence files or raw Graph observations. Signed finalization detects changes to scope, reviews or protected evidence without rewriting the existing immutable audit controls.

For integrity mismatches, stop relying on the conclusion and investigate the signed audit history and protected source evidence. Preserve prior data and keys. Reopening a finalized audit by changing its stored lifecycle field cannot bypass the signed finalization event through the API. Create a new audit snapshot for changed source catalogues or new testing periods.